Sprint 4 Static Analysis Summary – Budgetly

Repositories: budgetly_web_customer and budgetly_backend_nodejs (Budgetly-Project-Structure) | Analysis date: 2026-11-03

1. Tools Used

Tool	Details
SonarQube Cloud	Hosted SonarQube Cloud (sonarcloud.io), Automatic Analysis, "Sonar way" quality gate. Run in the cloud on GitHub forks of both repos. Languages: JavaScript/JSX, CSS, YAML.
Trivy 0.76.1	Filesystem scan (`trivy fs --scanners vuln`) of dependency lock files. Run locally on a fresh clone of each repo.

2. Required Metrics

SonarQube (Overall Code)

Metric	Web	Backend	Total
Bugs	13	15	28
Vulnerabilities	4	3	7
Code Smells	4	3	7
Security Hotspots	0	0	0
Quality Gate	Passed	Passed	Passed

Trivy

Severity	Web	Backend	Total
CRITICAL	0	0	0
HIGH	4	1	5
MEDIUM	4	2	6
LOW	2	0	2

3. Scope

Scanned: SonarQube analyzed all source code in both repositories (about 4.8k lines in web, 5.9k lines in backend). Trivy scanned the dependency lock files: `package-lock.json` (web), `functions/package-lock.json` (backend), and two Swift `Package.resolved` files (0 findings).

Excluded: SonarQube default exclusions (generated and vendored files, `node_modules`); no code coverage was configured. Trivy skipped development and test dependencies (its default) and did not run secret, misconfiguration or license scanners.

4. Trend vs. Previous Sprint

Metric	Sprint 3	Sprint 4	Change
Bugs	22	28	+6
Vulnerabilities	5	7	+2
Code Smells	7	7	0
Security Hotspots	0	0	0

Quality Gate	Passed	Passed	same
Trivy (C/H/M/L)	0 / 2 / 1 / 1	0 / 5 / 6 / 2	+9 total

Sprint 4 added the top-level transactions collection, soft delete and purge, and the monthly budget setup, so the codebase grew and findings rose. Trivy findings rose mainly because new vulnerability advisories were published for packages we already depend on (vite, @grpc/grpc-js, body-parser). All 13 Trivy findings list a fixed version.

5. Reflection

The most problematic area is reliability: 28 SonarQube bugs (the web project is rated D), plus 5 HIGH dependency vulnerabilities in vite, @grpc/grpc-js, re2js, source-map-js and body-parser. Next sprint we will upgrade those packages to the fixed versions Trivy lists, review the open SonarQube bugs by severity starting with the web project, and add both scans to the sprint checklist so counts are tracked before each sprint review.

This static analysis was generated using automated tools during this sprint.

Attached reports: Sonar_Budgetly_Web_Sprint_4.pdf, Sonar_Budgetly_Backend_Sprint_4.pdf, Trivy_Report_Sprint_4.pdf